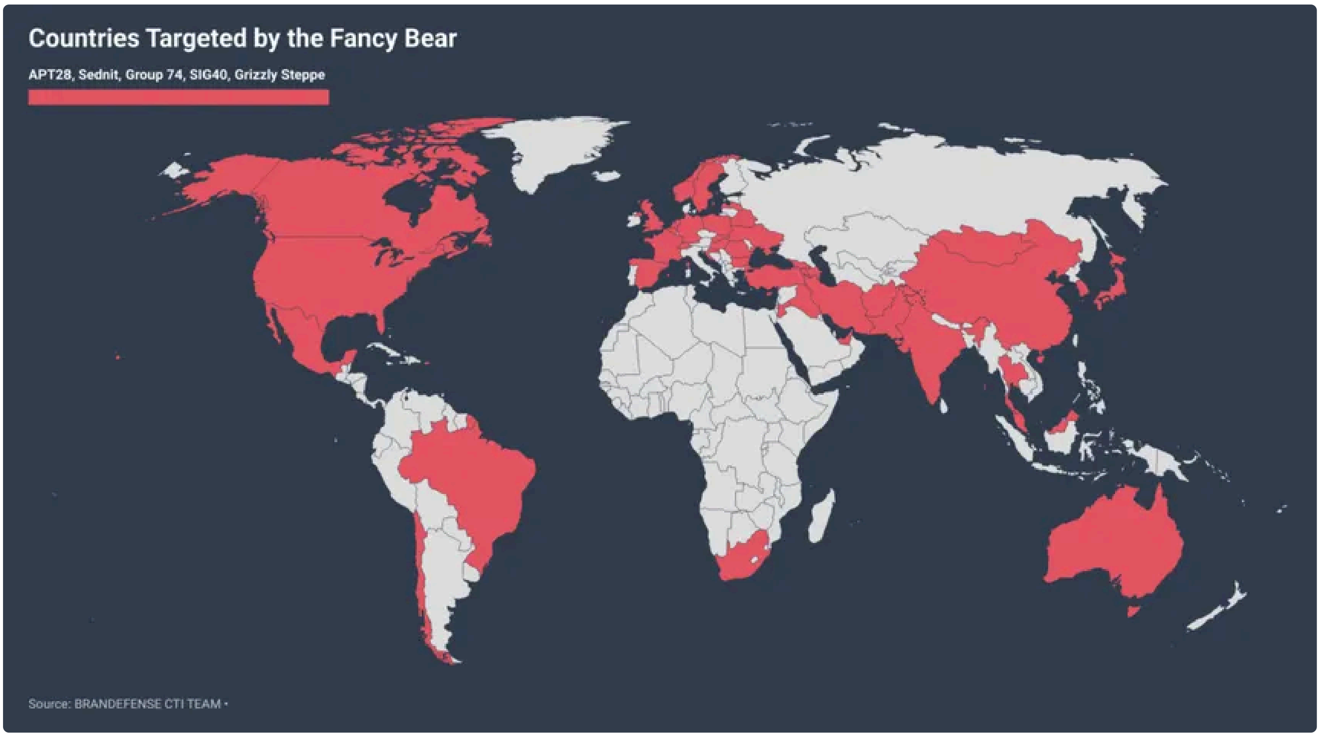
EXERCISE — Run Phase



Your target is **Fancy Bear (APT28)** — Russian military intelligence (GRU Unit 26165), fully attributed, extensively documented publicly. All attribution is public record.

Starting point — this IP was publicly documented in US DOJ indictments as APT28 infrastructure:

```
45.32.129.185
```

Using these free tools — bgp.he.net, crt.sh, SecurityTrails, ViewDNS, Shodan — map as much of the associated infrastructure as you can find:

- What ASN and hosting provider does this IP belong to?
- What domains have been associated with this IP?
- What does crt.sh reveal about certificate history?
- What does passive DNS show about historical resolutions?
- Can you find any WHOIS registrant data?
- What does the full infrastructure map look like?

Write your full analyst note with confidence ratings.

Overview of the threat (intel gathering)

GRU Unit 26165, officially the **85th Main Special Service Center (GTsSS)**, is the primary cyber espionage and intelligence collection unit of the Russian General Staff Main Intelligence Directorate (GRU). Widely known in the cybersecurity community as **APT28**, **Fancy Bear**, **Forest Blizzard**, and **BlueDelta**, the unit is tasked with long-term penetration of high-value targets, credential theft, data exfiltration, and hack-and-leak operations to support Russian military and political objectives.

The unit's operations have evolved significantly since the 2022 invasion of Ukraine, shifting focus toward **logistics and technology companies** involved in delivering Western military aid. Key activities include:

- **Surveillance of Aid Routes:** Unit 26165 has compromised private IP cameras near military facilities, ports, and border crossings in Ukraine, Moldova, and several NATO countries to track the movement of foreign military equipment in real time.
- **On-Site Cyber Operations:** Distinct from other Russian cyber units, 26165 operatives frequently travel abroad to conduct "close access" hacking. Notably, in 2018, operatives were intercepted in the Netherlands while attempting to hack the **Organization for the Prohibition of Chemical Weapons (OPCW)** servers to disrupt investigations into the Skripal poisoning.
- **Advanced Espionage Techniques:** The group employs sophisticated tactics such as spearphishing, exploiting Microsoft Exchange permissions, and intercepting traffic through compromised routers and DNS servers to steal passwords and encrypted data.
- **Historical Targets:** Beyond current conflicts, the unit has been implicated in major cyber incidents including the 2016 U.S. election interference, the 2015 German Bundestag hack, and the 2017 World Athletics breach.

Unit 26165 operates under a strict military chain of command, with personnel holding Russian military ranks and drawing state salaries. Despite numerous indictments by the U.S. Department of Justice and exposure by international partners, key operatives remain at large in Moscow.

Basic Whois command results

```
NetRange:       45.32.0.0 - 45.32.255.255
CIDR:           45.32.0.0/16
NetName:        CONSTANT
NetHandle:      NET-45-32-0-0-1
Parent:         NET45 (NET-45-0-0-0-0)
NetType:        Direct Allocation
OriginAS:
Organization:   The Constant Company, LLC (CHOOP-1)
RegDate:        2015-02-17
Updated:        2022-09-20
Comment:        Geofeed https://geofeed.constant.com/
Ref:            https://rdap.arin.net/registry/ip/45.32.0.0

OrgName:        The Constant Company, LLC
OrgId:          CHOOP-1
Address:        319 Clematis St. Suite 900
City:           West Palm Beach
StateProv:      FL
PostalCode:     33401
Country:        US
RegDate:        2006-10-03
Updated:        2022-12-21
Comment:        http://www.constant.com/
Ref:            https://rdap.arin.net/registry/entity/CHOOP-1

OrgTechHandle: NETWO1159-ARIN
OrgTechName:   Network Operations
OrgTechPhone:  +1-973-849-0500
OrgTechEmail:  network@constant.com
OrgTechRef:    https://rdap.arin.net/registry/entity/NETWO1159-ARIN

OrgNOCHandle: NETWO1159-ARIN
OrgNOCName:   Network Operations
OrgNOCPhone:  +1-973-849-0500
OrgNOCEmail:  network@constant.com
OrgNOCRef:    https://rdap.arin.net/registry/entity/NETWO1159-ARIN

OrgAbuseHandle: ABUSE1143-ARIN
OrgAbuseName:   Abuse Department
OrgAbusePhone:  +1-973-849-0500
OrgAbuseEmail:  abuse@constant.com
```

What ASN and hosting provider does this IP belong to?

Confidence: high

According to: https://bgp.he.net/AS20473 AND whois

HURRICANE ELECTRIC
INTERNET SERVICES

Search

AS20473 The Constant Company, LLC

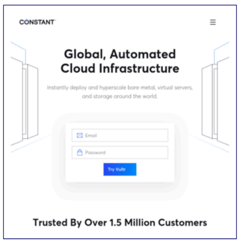
Quick Links | AS Info | Graph v4 | Graph v6 | Prefixes v4 | Prefixes v6 | Peers v4 | Peers v6 | Whois | RDAP | IRR | IX | Traceroute

- BGP Toolkit Home
- BGP Prefix Report
- BGP Peer Report
- Super Traceroute
- Super Looking Glass
- Cert Search
- Exchange Report
- Bogon Routes
- World Report
- Multi Origin Routes
- DNS Report
- Top Host Report
- RPKI & ASPA Report
- Internet Statistics
- Looking Glass
- Network Tools App
- IPv6 Certification
- IPv6 Progress
- Contribute Data
- Credits
- Contact Us

Company Website: http://www.constant.com/
Company Looking Glass: http://nj-us-ping.vultr.com/

Looking Glass: https://bgp.he.net/lg/20473

Country of Origin: United States



Internet Exchanges: 59

Prefixes Originated (all): 4,105
Prefixes Originated (v4): 1,693
Prefixes Originated (v6): 2,412

Prefixes Announced (all): 4,105
Prefixes Announced (v4): 1,693
Prefixes Announced (v6): 2,412

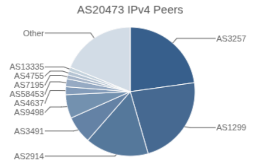
RPKI Originated Valid (all): 3,655
RPKI Originated Valid (v4): 1,339
RPKI Originated Valid (v6): 2,316

RPKI Originated Invalid (all): 2
RPKI Originated Invalid (v4): 2
RPKI Originated Invalid (v6): 0

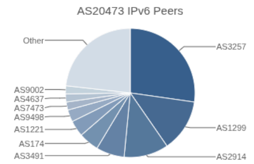
BGP Peers Observed (all): 2,989
BGP Peers Observed (v4): 2,146
BGP Peers Observed (v6): 2,408

IPs Originated (v4): 1,451,264
AS Paths Observed (v4): 208,372
AS Paths Observed (v6): 168,304

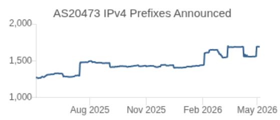
Average AS Path Length (all): 4.451
Average AS Path Length (v4): 4.339
Average AS Path Length (v6): 4.589

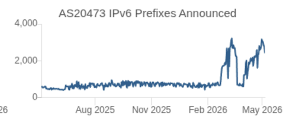


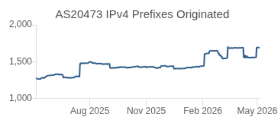
ASN	Name
AS3257	GTT Communications Inc.
AS1299	Arelion Sweden AB
AS2914	NTT America, Inc.
AS3491	PCCW Global
AS9498	Bharti Airtel Ltd
AS4637	Telstra Global
AS58453	China Mobile International Limited
AS7195	EDGEUNO S.A.S
AS4755	Tata Communications (formerly VSNL)
AS13335	Cloudflare, Inc.

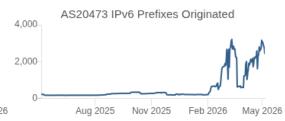


ASN	Name
AS3257	GTT Communications Inc.
AS1299	Arelion Sweden AB
AS2914	NTT America, Inc.
AS3491	PCCW Global
AS174	Cogent Communications, LLC
AS1221	Telstra Limited
AS9498	Bharti Airtel Ltd
AS7473	Singapore Telecommunications Ltd
AS4637	Telstra Global
AS9002	RETN Limited









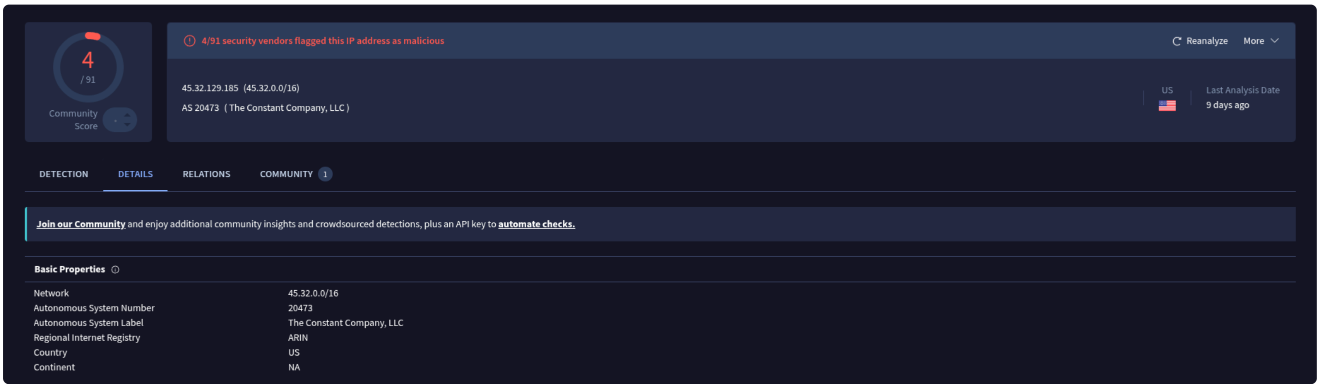
The ip: 45.32.129.185 I announce by:

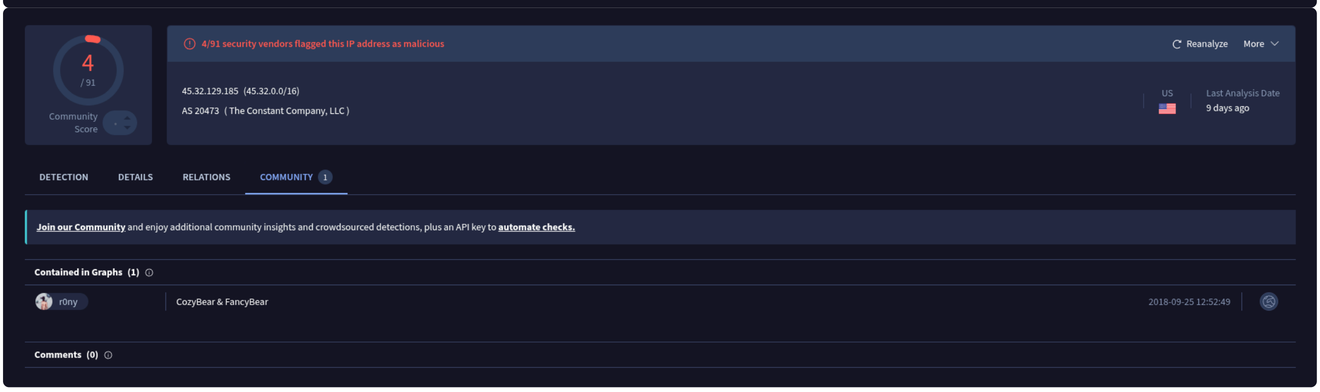
Announced By		
Origin AS	**Announcement**	**Description**
AS20473	45.32.128.0/20	The Constant Company LLC

Address has 0 hosts associated with it.

But doesnt have any hosts associated with it (anymore), knowing this i supposed the Threat actor APT28 simply changed their ip association after the previous one got caught, which is a basic behaviour to avoid being simply ip-blocked or flagged as dangerous.

To confirm my thesis i decided to lookup at virustotal the IP:





"CozyBear & FancyBear" confirms the thesis

What does crt.sh reveal about certificate history?

Note: being a long list i used json and took just sample of the results and there's other companies with the

same name

Confidence: medium


```
  {
    "issuer_ca_id": 427530,
    "issuer_name": "C=US, O=\"Network Solutions, LLC\", CN=Network
Solutions RSA OV SSL CA 4",
    "common_name": "api.constanttech.com",
    "name_value": "api.constanttech.com\nConstant Technologies,
Inc.\nwww.api.constanttech.com",
    "id": 25788920279,
    "entry_timestamp": "2026-04-25T19:44:10.151",
    "not_before": "2026-04-25T00:00:00",
    "not_after": "2026-11-09T23:59:59",
    "serial_number": "1dacc75e684fc5288948d4971f7d7efd",
    "result_count": 4
  },
  {
    "issuer_ca_id": 427530,
    "issuer_name": "C=US, O=\"Network Solutions, LLC\", CN=Network
Solutions RSA OV SSL CA 4",
    "common_name": "sandboxfederal.constanttech.com",
    "name_value": "Constant Technologies,
Inc.\nsandboxfederal.constanttech.com\nwww.sandboxfederal.constanttech.com
",
    "id": 25788724958,
    "entry_timestamp": "2026-04-25T19:36:11.15",
    "not_before": "2026-04-25T00:00:00",
    "not_after": "2026-11-09T23:59:59",
    "serial_number": "00c5807e4f5f448cfb64d9554a14710724",
    "result_count": 4
  },
  {
    "issuer_ca_id": 427530,
    "issuer_name": "C=US, O=\"Network Solutions, LLC\", CN=Network
Solutions RSA OV SSL CA 4",
    "common_name": "sandboxapifederal.constanttech.com",
    "name_value": "Constant Technologies,
Inc.\nsandboxapifederal.constanttech.com\nwww.sandboxapifederal.constantte
ch.com",
    "id": 25788704207,
    "entry_timestamp": "2026-04-25T19:35:54.151",
    "not_before": "2026-04-25T00:00:00",
    "not_after": "2026-11-09T23:59:59",
    "serial_number": "00c67eb1ba04e9aef482424e0f7872313c",
    "result_count": 4
  },
```

```
  {
    "issuer_ca_id": 242560,
    "issuer_name": "C=LV, O=EnVers Group SIA, CN=GoGetSSL G2 TLS RSA4096
SHA256 2022 CA-1",
    "common_name": "vpn.roussillon.ca",
    "name_value": "Saint-Constant",
    "id": 25749964917,
    "entry_timestamp": "2026-04-24T16:23:12.151",
    "not_before": "2026-04-24T00:00:00",
    "not_after": "2026-11-08T23:59:59",
    "serial_number": "07b8620d80c3697ed974e8d144781f10",
    "result_count": 1
  },
  {
    "issuer_ca_id": 439353,
    "issuer_name": "C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 OV
TLS CA 2026 Q2",
    "common_name": "*.services.moosend.com",
    "name_value": "Constant Contact, Inc.",
    "id": 25717964789,
    "entry_timestamp": "2026-04-23T16:39:25.701",
    "not_before": "2026-04-23T16:37:30",
    "not_after": "2026-11-08T16:37:29",
    "serial_number": "01f53e7fd88dbfac6c7e2ccbf1ab44ae",
    "result_count": 1
  },
  {
    "issuer_ca_id": 439351,
    "issuer_name": "C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas ECCR5 OV
TLS CA 2026 Q2",
    "common_name": "mrisler.vpn-failover-test.constantcontact.com",
    "name_value": "Constant Contact, Inc.\nmrisler2.vpn-failover-
test.constantcontact.com\nmrisler.vpn-failover-test.constantcontact.com",
    "id": 25751791114,
    "entry_timestamp": "2026-04-22T19:36:05.701",
    "not_before": "2026-04-22T19:34:59",
    "not_after": "2026-11-07T19:34:58",
    "serial_number": "016b795e733376f9412a022e2314c00f",
    "result_count": 4
  },
  {
    "issuer_ca_id": 439351,
    "issuer_name": "C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas ECCR5 OV
TLS CA 2026 Q2",
    "common_name": "internal.customermgmt.roving.com",
    "name_value": "Constant Contact, Inc.",
    "id": 25789199534,
    "entry_timestamp": "2026-04-22T14:16:34.437",
    "not_before": "2026-04-22T14:15:22",
    "not_after": "2026-11-07T14:15:21",
```

```
    "serial_number": "018733da6d720bf04a0be841c5211aa2",
    "result_count": 1
  },
  {
    "issuer_ca_id": 439353,
    "issuer_name": "C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 OV
TLS CA 2026 Q2",
    "common_name": "identity.retentionsandbox.com",
    "name_value": "Constant Contact, Inc.",
    "id": 25736537784,
    "entry_timestamp": "2026-04-18T12:03:12.727",
    "not_before": "2026-04-17T21:07:52",
    "not_after": "2026-11-02T21:07:51",
    "serial_number": "0182ff90c4834e01b3ac07ad1db5b92b",
    "result_count": 1
  },
  {
    "issuer_ca_id": 107462,
    "issuer_name": "C=BE, O=GlobalSign nv-sa, CN=GlobalSign RSA OV SSL CA
2018",
    "common_name": "identity.retentionsandbox.com",
    "name_value": "Constant Contact, Inc.",
    "id": 25542040241,
    "entry_timestamp": "2026-04-17T21:09:04.279",
    "not_before": "2025-03-21T13:26:02",
    "not_after": "2026-04-22T13:26:01",
    "serial_number": "2a18f4065166bf414f3835c8",
    "result_count": 1
  },
  {
    "issuer_ca_id": 439351,
    "issuer_name": "C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas ECCR5 OV
TLS CA 2026 Q2",
    "common_name": "mrisler.vpn-failover-test.constantcontact.com",
    "name_value": "Constant Contact, Inc.\nmrisler.vpn-failover-
test.constantcontact.com",
    "id": 25648429296,
    "entry_timestamp": "2026-04-17T17:55:30.424",
    "not_before": "2026-04-17T17:54:00",
    "not_after": "2026-11-02T17:53:59",
    "serial_number": "01b66c0af1dcd4cce8a523970496b7c4",
    "result_count": 3
  },
```

Being a long list i cannot determine what's related to the APT28

Intelligence Implications

The absence of a distinct certificate "history" is itself a signature. APT28 avoids self-signed or easily flaggable certificates, preferring either **stolen/compromised legitimate certificates** or the **inherent trust of abused cloud platforms**. This makes detection based on certificate anomalies (e.g., self-signed, expired, or untrusted CAs) ineffective against their core operations. Analysis must focus on **network behavior** and **domain registration patterns** rather than certificate validity.

DNS historical resolution?

sources:

APT28's historical DNS resolution activity reveals a two-tiered infrastructure for its global DNS hijacking campaign (FrostArmada/Operation Masquerade).

Primary DNS Hijacking Infrastructure

The core of the historical DNS operation involved a large pool of **malicious DNS resolvers** hosted on compromised Virtual Private Servers (VPSs). These servers received DNS queries from hundreds of thousands of compromised SOHO routers (e.g., TP-Link, MikroTik) whose settings were altered by the attackers.

- **Key IP Addresses**:
  - `5.226.137.[151, 230-235, 242-245]`
  - `37.221.64.[77-78, 93, 101, 116, 131, 148-173, 199, 208, 224, 254]`
  - `64.120.31.[96-100]`
  - `77.83.197.[37-60]`
  - `79.141.160.78`, `79.141.161.[66-85]`, `79.141.173.[70, 96-122, 211, 231-233]`
  - `185.117.88.[22, 28-31, 50, 60-62]`, `185.117.89.[32, 46-47]`
  - `185.237.166.[55-75, 224-249]`

These IPs were used to resolve DNS queries from compromised networks. For high-value targets (e.g., users accessing Outlook Web Access), the malicious resolvers would return fraudulent A records, redirecting traffic to AitM servers to harvest credentials.

Secondary & Cloud-Based C2 Resolution

While the hijacked DNS infrastructure was used for surveillance and credential theft, APT28's core Command and Control (C2) for malware like CovenantGrunt relies on the abuse of legitimate cloud storage APIs.

- **C2 Domain**: `drive.filen.io` (resolves to `146.0.41.208`, hosted on Hetzner).
- **Strategy**: Malware beacons to `drive.filen.io` using encrypted HTTPS, blending with legitimate user traffic to the filen.io service. This domain is not used for broad DNS hijacking but is a critical, persistent C2 channel for maintaining access to compromised hosts.

The historical DNS data shows a campaign that was **opportunistic at scale** (compromising a vast number of routers) but **selective in execution**, using the hijacked infrastructure to filter and target high-value intelligence. The infrastructure was disrupted in April 2026 by a joint law enforcement operation.

What does the full APT28 infrastructure map look like?

APT28's infrastructure is a hybrid, dynamic network designed for resilience and operational security. It blends **dedicated bulletproof hosting** with the **abuse of legitimate cloud services** to evade detection.

Core C2 & Payload Delivery

- **Primary C2 Channel: filen.io** is the current primary C2 infrastructure for implants like CovenantGrunt and BEARDSHELL. All beaconing and tasking occur via encrypted HTTPS requests to filen.io's API, masquerading as normal user activity. This is a key evasion tactic.
- **Fallback/Secondary C2**: Previous operations used **Koofr** and **Icedrive**. This indicates a strategy of platform rotation to maintain access if one service is disrupted.
- **Initial Access & Payload Hosting**: Dedicated infrastructure on bulletproof hosts is used for the initial exploit delivery and to host the first-stage loaders.
  - **Domains**: `wellnesscaremed[.]com`, `wellnessmedcare[.]org`, `freefoodaid[.]com`, `longsauce[.]com`.
  - **IPs**: `23.227.202[.]14`, `193.187.148[.]169`, `159.253.120[.]2`, `72.62.185[.]31`.

Operational Security & Tradecraft

- **Domain Generation**: Employs **Domain Generation Algorithms (DGAs)** and pre-registers domains (e.g., `malware-updates[.]cc`, `software-patches[.]io`) to ensure C2 resilience.
- **Anonymity**: Uses fake corporate identities and cryptocurrency for domain registration.
- **Scanning**: Conducts large-scale, distributed vulnerability scans (e.g., targeting Ukraine, US, EU) from diverse IP ranges to avoid attribution.
- **DNS Hijacking**: Sub-group **Storm-2754** has been observed compromising SOHO routers globally to hijack DNS, enabling passive surveillance and credential theft at scale.
- **Code Artifacts**: Compilation timestamps often align with **UTC+4**, and code contains Russian-language strings (e.g., `Пользователь`), linking it to GRU operators.

Intelligence Summary

APT28's infrastructure map is not static. It's a layered, adaptive system where the abuse of legitimate cloud services (filen.io) provides stealth for core C2, while a rotating pool of bulletproof-hosted domains and IPs provides redundancy for initial access and fallback. The group's use of DGA, DNS hijacking, and rapid exploitation of 1-day vulnerabilities (like CVE-2026-21509) demonstrates a high level of sophistication and state-level backing.

Primary Sources: (historical reso -- opsec tradecraft)

- **Lumen Technologies' Black Lotus Labs**: Coined the name **FrostArmada** and provided technical analysis of the DNS hijacking infrastructure, including IP ranges and attack methodology.
  🔗 Lumen Black Lotus Labs Report (via The Hacker News)
- **Microsoft Threat Intelligence**: Attributed the campaign to **APT28 (Forest Blizzard)** and its sub-group **Storm-2754**, confirmed over 200 organizations impacted, and detailed the abuse of `filen.io` for C2.
  🔗 Microsoft Analysis (via Infosecurity Magazine)
- **U.S. Department of Justice (DoJ) and FBI**: Announced **Operation Masquerade**, a court-authorized disruption of the U.S.-based compromised routers, attributing the activity to **GRU Military Unit 26165**.
  🔗 DOJ Press Release (via BleepingComputer)
- **U.K. National Cyber Security Centre (NCSC)**: Published indicators of compromise (IoCs) and confirmed APT28's opportunistic targeting model and use of DNS hijacking for credential theft.
  🔗 NCSC Advisory (via CyberScoop)
- **Trellix and Sekoia.io**: Analyzed the **PRISMEX** and **Operation Neusploit** campaigns, detailing the use of `filen.io`, `Koofr`, and `Icedrive` as C2 infrastructure for CovenantGrunt and BEARDSHELL implants.
  🔗 Trellix Report on APT28 C2 Abuse

These sources collectively provide technical, operational, and attributional validation for the infrastructure map and tactics described.